Control Assessment Matrix

Framework references and reviewer notes are collected in the final Supporting details section.

CTL-01

Security governance and responsibilities

Assessment result

Partially Met

Purpose and risk

Control objective	Roles, policies, accountability, and risk oversight
Risk addressed	Unclear accountability and delayed governance follow-up could leave security and third-party risks unassigned or unresolved, allowing control weaknesses to persist.

What the evidence shows

Design Is it defined properly?	The RACI names a security leader but leaves third-party risk accountability as “Shared / TBD.” The access policy is listed as approved, but its content and review requirements were not supplied.
Implementation Is it in place?	A security leadership owner and an approved access policy are recorded. Third-party risk lacks a clear accountable owner. Policy approval is a summary status; the approved policy and approval record are not included.
Operating effectiveness Does it work in use?	Governance follow-up has exceptions: the access-policy record says its review due date has passed, and an open risk committee action is marked high priority and overdue. Actual due dates and closure records are absent, so lateness cannot be independently recalculated.
Recorded gaps	Third-party risk accountability is 'Shared / TBD.' Access-policy review is recorded as overdue; a high-priority committee action is open and recorded as overdue. Specific dates and supporting policy/action records are not provided.
Why this result	A named security leader and an approved-policy status show governance is partly established. Unclear third-party risk accountability and reported overdue policy and committee follow-up limit its effectiveness. The summaries do not establish complete governance coverage.

What needs to happen

Assign a single accountable third-party risk owner; provide the approved policy, approval history, and review schedule; complete the policy review; resolve or formally reprioritize the committee action with an accountable owner, dates, and documented approval..

Owner (fictional role)	Director Security, with an assigned Third Party Risk Owner.

Scope and evidence

Evidence IDs	E-001-01; E-001-02
Assessment period	2026-10-01 to 2026-10-15. Both CTL-01 CSVs are undated summaries; actual record-period coverage is unverified.

CTL-02

Asset inventory and classification

Assessment result

Partially Met

Purpose and risk

Control objective	Identify relevant assets and classify information
Risk addressed	Incomplete asset ownership, review, or classification could leave payment-related systems unmanaged and sensitive information inadequately protected, increasing exposure to unauthorized changes or disclosure.

What the evidence shows

Design Is it defined properly?	The inventory records assets, owners, functions, and review dates, while the classification sample assigns data labels. Inventory completeness checks, classification rules, and review frequency are not documented in the supplied artifacts.
Implementation Is it in place?	Three assets and two data sets are recorded. Payment API and Support console have owners; CI/CD has none. Transaction tokens are classified Confidential. Support export is labelled Internal but its customer-contact fields are explicitly flagged for classification review.
Operating effectiveness Does it work in use?	Only Payment API has a review date (2026-10-01); CI/CD and Support console have blank last-review fields. No review cadence is supplied, so those blanks establish missing review evidence, not proven overdue reviews. The support-export classification remains flagged for review.
Recorded gaps	CI/CD owner is blank; CI/CD and Support console have no recorded review date. Support export's Internal classification requires review due to customer-contact fields. Full asset coverage and classification criteria are not established.
Why this result	Asset inventory and classification records demonstrate partial implementation. The CI/CD platform lacks an owner, and the support-export classification is flagged for review. Missing asset-review dates prevent confirmation that reviews occur consistently.

What needs to happen

Assign a CI/CD owner; review and record CI/CD and Support console inventory entries; reassess the support-export classification against approved rules; define a review cadence and reconcile inventory coverage to payment flows and administrative paths

Owner (fictional role)	Engineering Leadership / Designated CI/CD Asset owner

Scope and evidence

Evidence IDs	E-002-01; E-002-02
Assessment period	2026-10-01 to 2026-10-15. Payment API last review is 2026-10-01; other asset-review dates and classification-record dates are absent.

CTL-03

Third-party risk management

Assessment result

Partially Met

Purpose and risk

Control objective	Assess and monitor suppliers that can affect the service
Risk addressed	Incomplete oversight of critical service providers could leave assurance gaps and incident-response responsibilities unresolved, increasing the risk of payment-service disruption or delayed response to a vendor incident.

What the evidence shows

Design Is it defined properly?	Vendor records include criticality and review dates, and follow-up actions have owners and statuses. The supplied artifacts do not define review frequency, acceptance criteria, or escalation requirements
Implementation Is it in place?	Three vendors are inventoried: the processor and cloud host are Critical and the ticketing vendor is Medium. Cloud host is marked Reviewed. Legal / Security owns notification terms and Security owns assurance review; processor assurance evidence is pending.
Operating effectiveness Does it work in use?	The processor's review date is 2026-06-01 and the cloud host's is 2026-10-01; ticketing vendor has no review date. Notification terms are Open without documented risk acceptance, and assurance review is In progress with evidence pending. No cadence or target date supports calling these items overdue.
Recorded gaps	Processor current assurance report is requested but not attached. Incident-notification terms are open without documented risk acceptance. Ticketing vendor review date is missing. Completion and quality of review work are not established by status fields.
Why this result	Vendor criticality records and assigned follow-up actions show oversight is partly established. The processor’s assurance review remains incomplete, incident-notification terms are unresolved, and the ticketing vendor lacks a review date. These gaps limit assurance over vendor oversight.

What needs to happen

Obtain and evaluate the processor's current assurance report; resolve incident-notification terms or document an authorized risk decision; obtain ticketing-vendor review evidence; define review frequency, acceptance requirements, and action deadlines.

Owner (fictional role)	Security, with Legal support, for incident notification terms

Scope and evidence

Evidence IDs	E-003-01; E-003-02
Assessment period	2026-10-01 to 2026-10-15. Review dates: processor 2026-06-01 (older than the window); cloud host 2026-10-01; ticketing vendor and action dates absent.

CTL-04

Access lifecycle and access reviews

Assessment result

Partially Met

Purpose and risk

Control objective	Approve, provision, review, and terminate user access
Risk addressed	Failure to reconcile termination records with account status could leave former personnel with unauthorized access, enabling inappropriate activity or disclosure of business information.

What the evidence shows

Design Is it defined properly?	The roster and quarterly review sample record approvals and review status. The supplied artifacts do not define termination deadlines, review-coverage requirements, or exception follow-up procedures.
Implementation Is it in place?	USR-001 and USR-002 are Active with Approval='Yes' and are marked Reviewed / Signed off in the quarterly sample. USR-023 and USR-024 have Status='Terminated' but the Approval field says 'Active in export'; their account state needs source-system confirmation.
Operating effectiveness Does it work in use?	Two of four sampled users are Reviewed / Signed off; USR-023 and USR-024 are Not reviewed with follow-up not attached. Those two also carry the 'Active in export' notation despite Terminated status. The sample therefore shows incomplete review coverage and unresolved termination/access reconciliation.
Recorded gaps	USR-023 and USR-024 are terminated but annotated Active in export; both are Not reviewed with no attached follow-up. USR-024 lacks a last-review date. Approval fields and sign-off summaries are not the underlying approvals, system-state export, or signed review records.
Why this result	Two active-user entries have recorded approvals and completed review statuses. Both former-user entries are unreviewed and carry unresolved “Active in export” annotations. The sample shows incomplete review coverage, while actual post-termination access remains unverified.

What needs to happen

Reconcile USR-023 and USR-024 to identity-provider and application account states; remove access where no longer authorized; complete their reviews and retain follow-up evidence. Provide source approval/sign-off records and define termination timing and review-completeness checks.

Owner (fictional role)	Access Management with HR and relevant Systems Owners.

Scope and evidence

Evidence IDs	E-004-01; E-004-02
Assessment period	2026-10-01 to 2026-10-15. USR-001, USR-002, and USR-023 show last review 2026-09-30 (before the window); USR-024 is undated. Quarterly review sample has no dates.

CTL-05

Privileged access and MFA

Assessment result

Partially Met

Purpose and risk

Control objective	Restrict privileged access and enforce applicable authentication requirements
Risk addressed	Unclear privileged-account ownership, unverified authorization, and inadequate authentication safeguards could permit unauthorized administrative access, compromising systems that support payment processing.

What the evidence shows

Design Is it defined properly?	The documented approach links privileged accounts to named owners, approval references, MFA settings, and an approved break-glass exception with compensating controls. A governing access standard, service-account requirements, and testing frequency are not supplied.
Implementation Is it in place?	PA-001–PA-009 have named owners, approvals, and MFA enforcement recorded. PA-010 is active with owner Unassigned, no approval reference, and unknown enforcement. PA-012 has unclear ownership, no approval record, and an undocumented authentication method. PA-011 has approved exception EX-01.
Operating effectiveness Does it work in use?	Logs show successful MFA for PA-001/002/003 on October 13–15. PA-010's October 14 MFA outcome is Unknown. PA-011's October 13 use has no recorded MFA outcome; post-use review is not supplied. EX-01 lists a May 1 test, but no required retest interval is stated.
Recorded gaps	PA-010 lacks assigned ownership and an approval record; enforcement is unknown. PA-012 ownership, authorization, and authentication safeguards need clarification. PA-011 post-use review and current compensating-control operation are unverified; its approved exception has not expired at October 15.
Why this result	Nine accounts have recorded owners, approvals, and MFA enforcement. PA-010 lacks an assigned owner and approval record, and its MFA enforcement is unknown. PA-012’s authentication safeguards and PA-011’s post-use review also remain unverified.

What needs to happen

Assign and validate PA-010 ownership and approval; verify/enforce MFA and retain outcomes. Validate PA-012 authorization, owner, and service-account safeguards. Obtain PA-011 post-use review and test evidence for EX-01 safeguards; define a retest interval before judging test freshness.

Owner (fictional role)	IAM Management / Privileged Access Owner

Scope and evidence

Evidence IDs	E-005-01; E-005-02; E-005-03; E-005-04; E-005-05
Assessment period	2026-10-01–15. Authentication events: October 13–15. EX-01 last tested May 1; expiry December 31, 2026. Account/configuration/approval extracts are undated.

CTL-06

Change management

Assessment result

Partially Met

Purpose and risk

Control objective	Authorize, test, and document relevant system changes
Risk addressed	Changes deployed without timely authorization, adequate testing, or appropriate emergency review could introduce insecure or unstable functionality, disrupting services or weakening payment-system security.

What the evidence shows

Design Is it defined properly?	The sample distinguishes normal changes with approval/testing from an emergency path and a post-implementation review field. Approval sequencing is visible; the full change procedure, mandatory testing requirements, and emergency-review deadline are not supplied.
Implementation Is it in place?	CHG-100 records pre-deployment approval and attached test evidence; CHG-102 also records pre-deployment approval. CHG-103 follows an emergency path. CHG-101 records approval after deployment, and CHG-102 testing is marked Missing.
Operating effectiveness Does it work in use?	One of three normal changes records approval after deployment (CHG-101); another lacks test evidence (CHG-102). CHG-103 has no evidenced post-implementation review and testing is Not shown. CHG-100 is described as complete; underlying attachments were not supplied.
Recorded gaps	CHG-101 approval follows deployment; CHG-102 test evidence is Missing; CHG-103 test evidence is Not shown and emergency review is not evidenced. Missing documentation does not establish that testing or review never occurred.
Why this result	CHG-100 records pre-deployment approval and testing, demonstrating partial implementation. CHG-101 records approval after deployment. Missing testing records for CHG-102 and incomplete testing and emergency-review evidence for CHG-103 prevent confirmation that the process is consistently followed.

What needs to happen

Investigate CHG-101 approval timing; require normal approval before deployment. Obtain CHG-102/103 testing records and CHG-103 emergency-review evidence; resolve undocumented exceptions. Define and enforce approval, test-retention, and emergency-review requirements.

Owner (fictional role)	Change Management Owner, with Engineering support.

Scope and evidence

Evidence IDs	E-006-01; E-006-02
Assessment period	2026-10-01–15. Both change evidence files are undated; actual deployment, approval, testing, and review dates are not supplied.

CTL-07

Vulnerability management

Assessment result

Partially Met

Purpose and risk

Control objective	Identify, prioritize, and remediate vulnerabilities
Risk addressed	Incomplete scanning coverage and delayed remediation or exception reassessment could leave exploitable vulnerabilities unresolved, exposing payment-supporting systems to compromise or disruption.

What the evidence shows

Design Is it defined properly?	The records define an approach of scanning assets, assigning finding severity and remediation targets, and tracking exceptions. They do not specify scanning frequency, approved asset scope, remediation SLAs, or exception-renewal requirements.
Implementation Is it in place?	Payment API and Cloud DB are recorded as scanned; their High findings VUL-01/02 remain Open. VUL-01 has an assigned ticket and October 20 target. Admin host is explicitly Not in scan scope. A Medium VUL-03 exception is recorded as expired.
Operating effectiveness Does it work in use?	VUL-02 has an October 1 target and is labeled overdue without an updated target. VUL-03 has an expired exception and blank reassessment. VUL-01's October 20 target is after the declared October 15 cutoff and is not yet overdue at that cutoff. Remediation closure is not demonstrated.
Recorded gaps	Admin host is excluded from scan scope; justification and relevance to the assessed boundary are unverified. VUL-02 is overdue; VUL-03's exception is expired with no recorded reassessment. VUL-01/02 remain open; an open High finding alone does not establish a missed deadline.
Why this result	Scanning and remediation targets are recorded, but VUL-02 is overdue and VUL-03’s exception has expired without recorded reassessment. The Admin host’s exclusion from scanning also requires scope confirmation. VUL-01 was not yet overdue at the October 15 cutoff.

What needs to happen

Confirm and justify the scan boundary; include Admin host if relevant. Resolve VUL-02 or approve a justified exception with a current target; reassess VUL-03 and document approval/controls. Track VUL-01 to its October 20 target and obtain verified closure evidence.

Owner (fictional role)	Vulnerability Management Owner, with affected Systems Owner

Scope and evidence

Evidence IDs	E-007-01; E-007-02
Assessment period	2026-10-01–15. Targets: VUL-01 October 20; VUL-02 October 1; VUL-03 September 30, 2026. Scan and extract dates are not supplied.

CTL-08

Logging and monitoring

Assessment result

Partially Met

Purpose and risk

Control objective	Record and review security-relevant events
Risk addressed	Incomplete security logging and unsupported alert-triage decisions could delay detection, investigation, and response to security incidents.

What the evidence shows

Design Is it defined properly?	The recorded approach combines centralized security logs, retention fields, alert severity, disposition, and analyst notes. The full logging scope, required retention duration, and required alert-review/closure criteria are not defined in the supplied files.
Implementation Is it in place?	Payment API and identity provider are recorded as logging centrally with 90-day retention. Database logging, centralization, and retention are Unknown. Support console has a row marked Not listed/Check scope. Three alerts have recorded dispositions.
Operating effectiveness Does it work in use?	High alert ALT-01 is Closed benign with No supporting notes; ALT-02 is Investigated with Analyst notes attached; ALT-03 is Closed/Routine. The attached notes were not supplied separately, and logs do not demonstrate continuous collection or actual retention performance.
Recorded gaps	ALT-01 has no supporting closure notes. Database safeguards are unknown; support-console coverage needs scope confirmation. Recorded 90-day settings do not demonstrate the required retention period or actual retained logs; lack of notes does not prove the benign decision was wrong.
Why this result	Centralized logging is recorded for two systems, and sampled alerts have documented dispositions. However, high-severity ALT-01 lacks supporting closure notes. Database and support-console coverage remain unverified, limiting assurance over logging completeness and consistent alert review.

What needs to happen

Obtain ALT-01 investigation rationale and supporting notes. Verify database logging and support-console scope/configuration; define retention requirements and test actual retention. Require documented alert-review rationale and independently inspect ALT-02 notes and representative source logs.

Owner (fictional role)	Security Operations / Logging and Monitoring Owners

Scope and evidence

Evidence IDs	E-008-01; E-008-02
Assessment period	2026-10-01–15. Coverage and alert files contain no event, review, or extract dates; actual operation during this window is unverified.

CTL-09

Incident response

Assessment result

Partially Met

Purpose and risk

Control objective	Prepare for, report, investigate, and learn from incidents
Risk addressed	Incomplete investigation, unresolved exercise actions, and unclear processor-coordination procedures could delay containment and recovery, increasing the duration and impact of a security incident.

What the evidence shows

Design Is it defined properly?	The response-plan summary identifies an incident commander, security contact, escalation, and communication roles. Processor-coordination steps are described as generic, limiting the documented design for the external payment dependency (E-009-01).
Implementation Is it in place?	A response-plan summary is present. E-009-02 records INC-01 as closed with timeline/closure notes and TTX-01 as completed. The underlying timeline, closure notes, and exercise records are not supplied separately.
Operating effectiveness Does it work in use?	Follow-up documentation is incomplete in the sample: INC-01 lacks root-cause analysis; two TTX-01 actions remain open and no retest is recorded. The summary does not establish action due dates, repeated performance, or full incident coverage.
Recorded gaps	Generic processor-coordination steps; missing INC-01 root-cause analysis; two open TTX-01 actions with no recorded retest. The records do not show that the open actions are overdue.
Why this result	Response roles are described, and a tabletop exercise is recorded as completed. Generic processor-coordination procedures, missing INC-01 root-cause analysis, and unresolved tabletop actions limit support for effective coordination and follow-up. The records do not establish that the open actions are overdue.

What needs to happen

Specify processor contacts, escalation responsibilities, and coordination steps; document INC-01 root-cause analysis; assign owners/dates for TTX-01 actions and record closure and a retest where appropriate; retain underlying incident and exercise records.

Owner (fictional role)	Incident Response Owner, with Security and Payment Processor Relations Owners

Scope and evidence

Evidence IDs	E-009-01; E-009-02
Assessment period	2026-10-01 to 2026-10-15. Both supplied source artifacts are undated; coverage of this period is not independently established.

CTL-10

Sensitive data protection

Assessment result

Partially Met

Purpose and risk

Control objective	Protect sensitive information through appropriate safeguards
Risk addressed	Incomplete identification of sensitive-data flows and inadequate encryption or retention controls could expose payment or customer information to unauthorized disclosure or retention beyond justified business needs.

What the evidence shows

Design Is it defined properly?	The data-flow summary describes temporary card-data handling by the payment API, transmission to the processor, and retention of tokens/transaction metadata. It explicitly leaves one support-export path unmapped; full data-protection design cannot be evaluated from this summary (E-010-01).
Implementation Is it in place?	E-010-02 lists TLS 1.2+ for the processor connection as shown in the sample. Analytics encryption at rest is marked Unknown / Not evidenced, and the support-export retention entry is incomplete. These entries do not establish the full technical configuration.
Operating effectiveness Does it work in use?	Retention documentation is incomplete: the sample lists a missing support-export retention date and notes two exports without approved retention rationale. Actual deletion/retention execution and analytics encryption operation are not demonstrated.
Recorded gaps	One unmapped support-export path; unknown/unevidenced analytics encryption at rest; missing export retention date; two exports lack approved retention rationale. Unknown encryption does not prove encryption is disabled.
Why this result	The primary payment flow and processor TLS setting are documented. However, one support-export path is unmapped and export-retention documentation is incomplete. Analytics encryption at rest and the technical enforcement of retention controls remain unverified.

What needs to happen

Map the support-export path and data elements; inspect processor and analytics encryption configurations; approve export retention requirements and dates; verify retention execution and retain supporting records. Confirm the full sensitive-data/system population

Owner (fictional role)	Data Protection Owner with Analytics, and Support Operations Owners.

Scope and evidence

Evidence IDs	E-010-01; E-010-02
Assessment period	2026-10-01 to 2026-10-15. The narrative and configuration/retention sample contain no record dates; period coverage is unverified.

CTL-11

Backup and recovery

Assessment result

Partially Met

Purpose and risk

Control objective	Back up relevant systems/data and test restoration
Risk addressed	Incomplete backup coverage or restoration that does not meet recovery needs could prolong outages or result in information loss, disrupting payment services and business operations.

What the evidence shows

Design Is it defined properly?	Backup coverage lists daily backups for the Payment database and Configuration store. Identity-configuration coverage is unknown. A restore sample exists, but its recovery time is not compared with an approved objective; the evidence does not define full scope or recovery acceptance criteria.
Implementation Is it in place?	E-011-01 reports successful daily-backup samples for the Payment database and Configuration store. E-011-02 reports a successful Payment DB restore and a roster of four backup administrators. Identity-configuration backups are not evidenced.
Operating effectiveness Does it work in use?	The sample reports successful backups and one successful restore, but provides no dates, history, measured recovery time, or objective comparison. One of four administrators lacks recent access-review evidence. Consistent recovery performance and full review coverage cannot be established.
Recorded gaps	Identity-configuration backup coverage is unknown; restore recovery time was not compared with an approved objective; one of four administrators lacks recent access-review evidence. These gaps do not prove backup absence, recovery failure, or inappropriate access.
Why this result	Selected backups and a Payment DB restore are recorded as successful. Restore performance was not compared with an approved recovery objective, leaving recovery validation incomplete. Identity-configuration backup coverage and the missing administrator access review require further evidence.

What needs to happen

Reconcile relevant systems to backup coverage, including identity configuration; obtain dated job/restore records and approved recovery objectives; compare measured restore performance with those objectives; obtain or perform the missing administrator review and document the outcome.

Owner (fictional role)	Backup and Disaster Recovery Owner, with Identity and System Owners

Scope and evidence

Evidence IDs	E-011-01; E-011-02
Assessment period	2026-10-01 to 2026-10-15. Backup and restore summaries are undated; the actual test period and frequency of successful operation are unverified.

CTL-12

Payment transaction integrity

Assessment result

Partially Met

Purpose and risk

Control objective	Protect transaction processing and reconcile exceptions
Risk addressed	Unresolved reconciliation exceptions or inadequately reviewed payment-routing changes could allow transaction errors or unauthorized changes to remain undetected, causing financial loss or inaccurate payment processing.

What the evidence shows

Design Is it defined properly?	The transaction-control narrative describes authorization, transaction references, and reconciliation. It explicitly states that technical implementation evidence is limited; detailed control rules and independent routing-change review requirements are not supplied (E-012-01).
Implementation Is it in place?	E-012-02 records a documented resolution for REC-01 and includes reconciliation exceptions and a routing change. This supports activity in the sample, while technical enforcement of the narrative and independent routing-change review remain unverified.
Operating effectiveness Does it work in use?	REC-02 is explicitly pending beyond target. REC-03 is closed without a documented resolution reason, and PAY-CHG-01 lacks independent-review evidence. REC-01 is recorded resolved, but the sample does not establish consistent reconciliation or change-review performance.
Recorded gaps	REC-02 pending beyond target; REC-03 resolution reason undocumented; PAY-CHG-01 independent-review evidence missing; limited technical implementation evidence. No target date is supplied to quantify REC-02 lateness.
Why this result	The narrative describes transaction controls, and REC-01 has a recorded resolution. REC-02 remains pending beyond target, while REC-03 lacks a documented resolution reason. Independent routing-change review and technical control enforcement remain unverified.

What needs to happen

Resolve REC-02 and retain dated follow-up; document REC-03's resolution reason; obtain PAY-CHG-01 independent-review evidence or investigate the review gap; define/retain routing-change approvals and obtain technical control configurations and dated transaction/reconciliation records.

Owner (fictional role)	Payment Operations Owners, with Change Management support

Scope and evidence

Evidence IDs	E-012-01; E-012-02
Assessment period	2026-10-01 to 2026-10-15. Narrative and reconciliation/change records contain no dates; period coverage and the length of REC-02 delay cannot be verified.

Supporting details

Proposed framework references and additional reviewer notes for each control.

CTL-01 Security governance and responsibilities

Proposed framework references	NIST CSF 2.0 Govern function; organizational context, roles, policy, and risk-management outcomes PCI: PCI DSS v4.0.1 Requirement 12 family; applicability and exact requirement text to verify SOC 2 Security Common Criteria CC1, CC2, CC3 (proposed)
Reviewer notes	Policy content, approval history, and actual overdue dates were not supplied. The summaries do not establish complete governance coverage.

CTL-02 Asset inventory and classification

Proposed framework references	NIST CSF 2.0 Identify function; asset-management outcomes PCI: PCI DSS v4.0.1 Requirement 12 family; CDE/system-component inventory applicability to verify SOC 2 Security Common Criteria CC6 and CC9 (proposed)
Reviewer notes	The sample does not establish a complete asset inventory, approved classification rules, or required review frequency.

CTL-03 Third-party risk management

Proposed framework references	NIST CSF 2.0 Govern/Identify functions; supplier and risk-management outcomes PCI: PCI DSS v4.0.1 Requirement 12 family; third-party/service-provider applicability to verify SOC 2 Security Common Criteria CC3 and CC9 (proposed)
Reviewer notes	Assurance reports, contracts, and completed vendor-review records were not supplied.

CTL-04 Access lifecycle and access reviews

Proposed framework references	NIST CSF 2.0 Protect function; identity-management and access-control outcomes PCI: PCI DSS v4.0.1 Requirements 7 and 8 families; applicability to verify SOC 2 Security Common Criteria CC6 (proposed)
Reviewer notes	“Active in export” appears in the Approval field. Actual account status and post-termination access require verification.

Supporting details (continued)

CTL-05 Privileged access and MFA

Proposed framework references	NIST CSF 2.0 Protect function; identity-management, authentication, and access-control outcomes PCI: PCI DSS v4.0.1 Requirements 7 and 8 families; applicability to verify SOC 2 Security Common Criteria CC6 (proposed)
Reviewer notes	Underlying configuration records, approval tickets, and emergency post-use reviews were not supplied. Authentication logs cover only a limited sample.

CTL-06 Change management

Proposed framework references	NIST CSF 2.0 Protect function; platform-security and change-control outcomes PCI: PCI DSS v4.0.1 Requirement 6 family; applicability to verify SOC 2 Security Common Criteria CC8 (proposed)
Reviewer notes	Four changes were sampled. Referenced test attachments and emergency-review records were not supplied.

CTL-07 Vulnerability management

Proposed framework references	NIST CSF 2.0 Protect/Detect functions; vulnerability-management and monitoring outcomes PCI: PCI DSS v4.0.1 Requirements 6 and 11 families; applicability to verify SOC 2 Security Common Criteria CC7 and CC8 (proposed)
Reviewer notes	Scan dates and complete asset coverage were not established. Underlying remediation tickets and exception approvals were not supplied.

CTL-08 Logging and monitoring

Proposed framework references	NIST CSF 2.0 Detect function; continuous-monitoring outcomes PCI: PCI DSS v4.0.1 Requirement 10 family; applicability to verify SOC 2 Security Common Criteria CC7 (proposed)
Reviewer notes	Source logs, configuration records, and referenced analyst notes were not supplied. Actual logging coverage and retention remain unverified.

Supporting details (continued)

CTL-09 Incident response

Proposed framework references	NIST CSF 2.0 Respond function; incident-management outcomes PCI: PCI DSS v4.0.1 Requirement 12 family; incident-response applicability to verify SOC 2 Security Common Criteria CC7 (proposed)
Reviewer notes	The plan and activity records are summaries. Underlying incident records, exercise results, action deadlines, and retest evidence were not supplied.

CTL-10 Sensitive data protection

Proposed framework references	NIST CSF 2.0 Protect function; data-security outcomes PCI: PCI DSS v4.0.1 Requirements 3 and 4 families when cardholder data is stored, processed, or transmitted; applicability to verify SOC 2 Security Common Criteria CC6 (proposed)
Reviewer notes	Technical settings were not independently verified. The two support exports are mentioned but are not individually identified.

CTL-11 Backup and recovery

Proposed framework references	NIST CSF 2.0 Recover function; recovery and restoration outcomes PCI: PCI DSS v4.0.1 applicability is context-dependent; verify before assessment SOC 2 Security Common Criteria CC7; Availability A1 only if availability commitments are in scope (proposed)
Reviewer notes	The summaries are undated. Underlying backup histories, restore reports, recovery objectives, and administrator-review records were not supplied.

CTL-12 Payment transaction integrity

Proposed framework references	NIST CSF 2.0 Protect/Detect functions; data security and monitoring outcomes PCI: PCI DSS v4.0.1 Requirements 3, 4, 6, and 10 families may be relevant; applicability to verify
Reviewer notes	Underlying resolution records, routing-change approvals, and technical test results were not supplied. The reconciliation delay cannot be quantified.